Episode 6

Security by Design – Think Like an Architect

Emad Adel — Cloud Solution Architect | Microsoft MVP

Think Like an Architect

المعمارية بـبساطة



Think Like an Architect

Episode 1 - Who is a Solutions Architect?
Episode 2 - Architectural Thinking
Episode 3 - Requirements Gathering
Episode 4 - **Architecture Patterns**, **Templates** & **Diagrams**
Episode 5 - How Solutions Architects Think About **Data**



The Big Misconception

Security is NOT

- A checklist
- A final phase
- Only the security team's job
- A post-deployment bolt-on

Security IS

Architectural responsibility —design decisions, trade-offs, and Constraints from day one.

When security is added late, the design is already compromised.



Security was

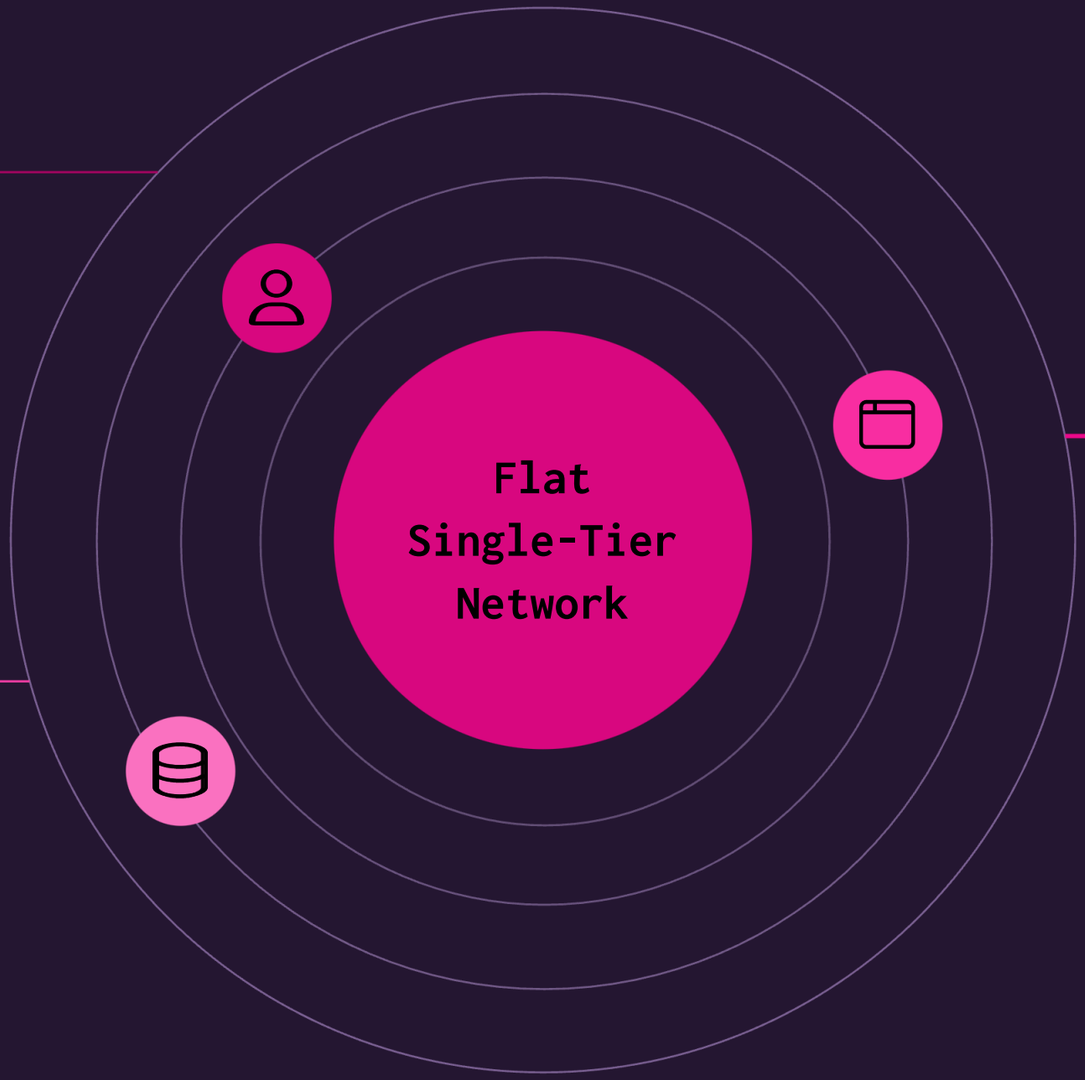


User

End user with shared access

Database

Central datastore, shared creds



Application

Single-tier app, implicit trust



This traditional model centralizes trust and resources. One compromise often becomes a full-system failure: shared credentials, no segmentation, and limited visibility.

Security by Design: Core Tenets

Security by Design is a foundational methodology that embeds security considerations into every stage of a system's development lifecycle, rather than treating it as an afterthought.

Integrate Early

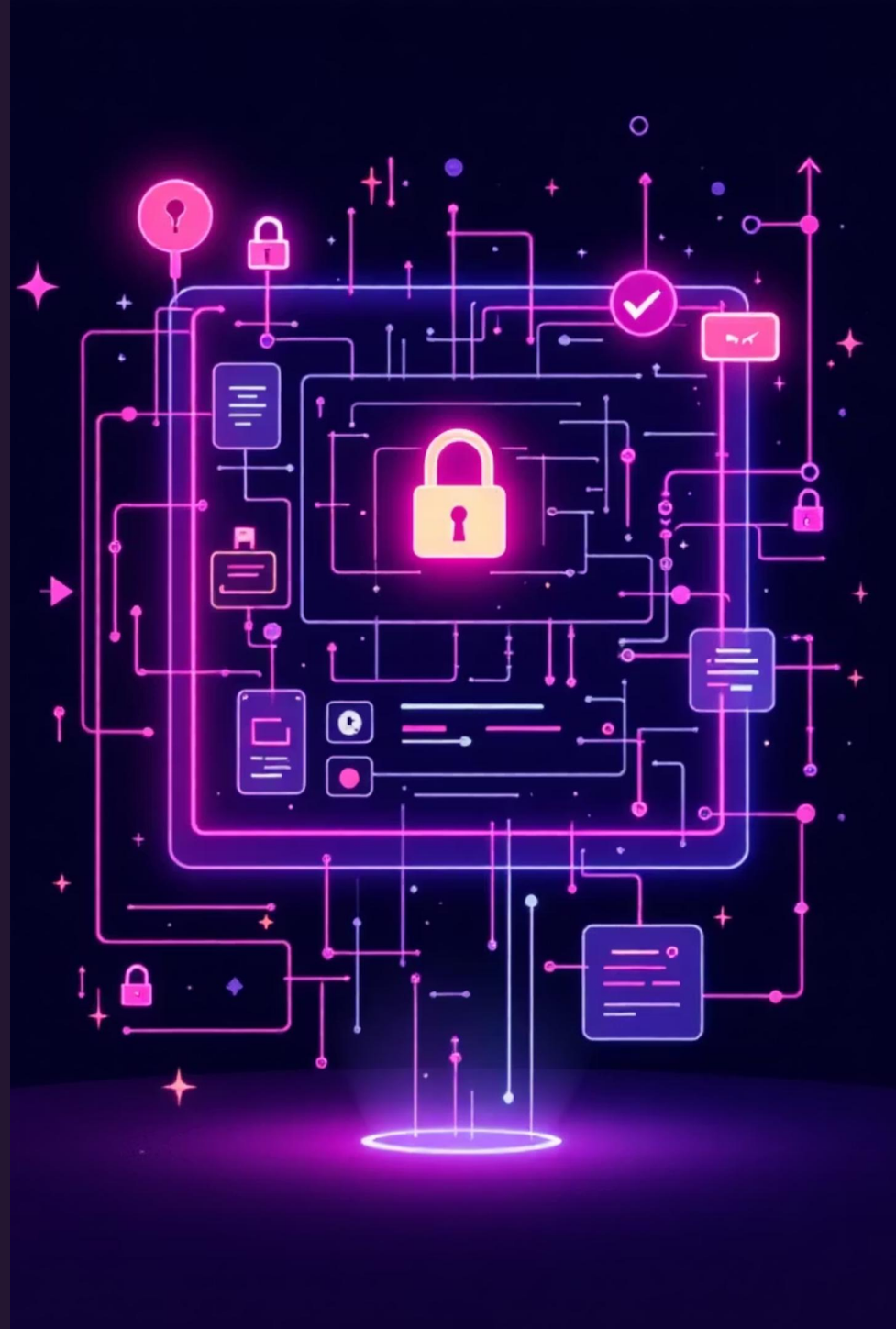
Embed security into architectural decisions from project inception, not as a later add-on.

Proactive Defense

Anticipate potential threats and vulnerabilities, building resilience into the system from the ground up.

Layered Approach

Implement robust security controls across all system components and architectural layers for comprehensive protection.



9 Security Architecture Principles

01 Least Privilege from Day One

02 Network Must Not Be Flat

03 Secrets Must Live Outside Code

04 Logging from Day Zero

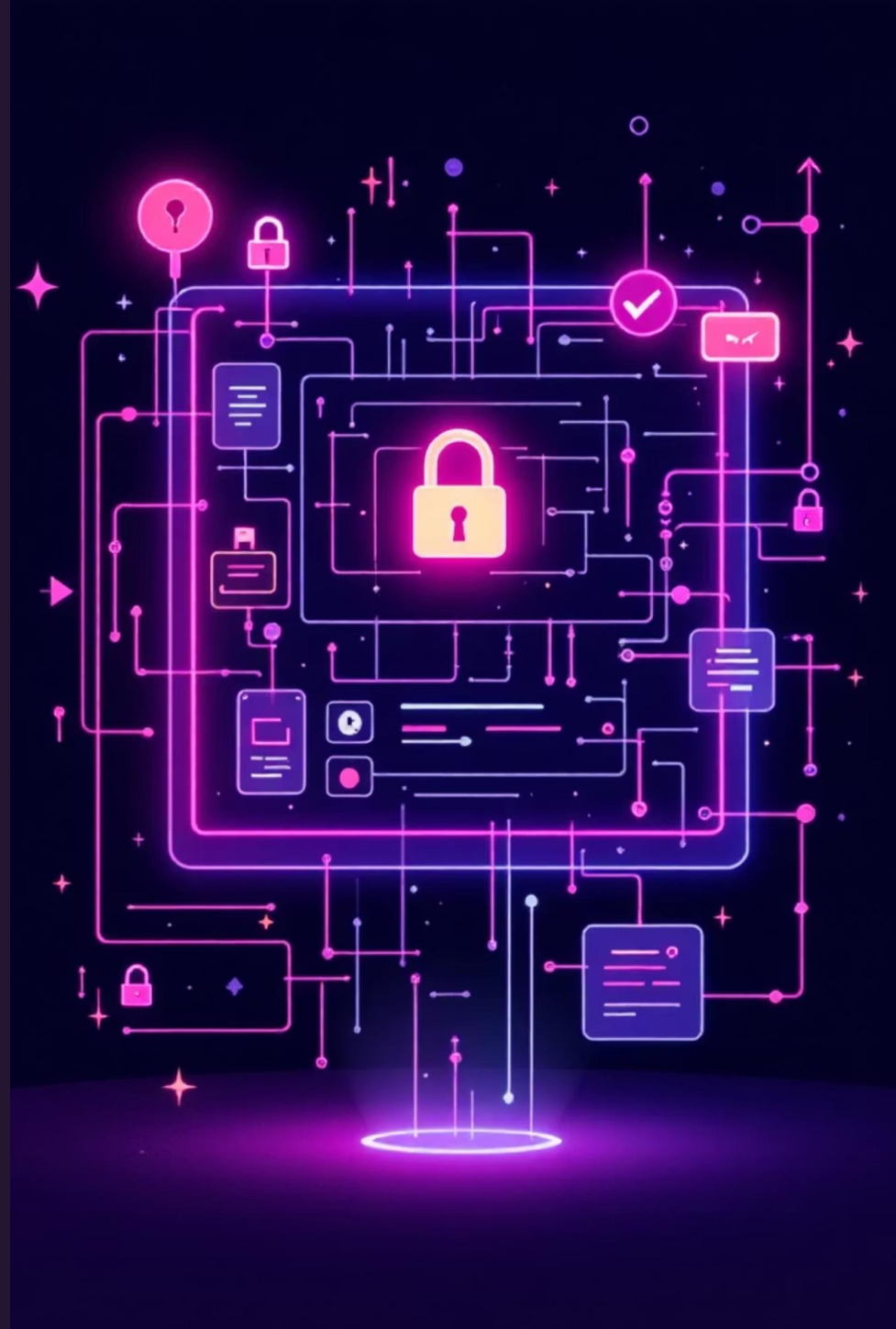
05 Assume Breach: Design for Reduced Impact

06 Zero Trust Architecture

07 Threat Modeling: Know Your Attack Surface

08 DevSecOps: Shift Security Left

09 Data Classification & Protection by Design



1 — Least Privilege from Day One

No default admin access

Start with deny-by-default. Only grant explicit permissions required for each role.

RBAC & service identities

Bind minimal roles to human and service identities; prefer ephemeral credentials and managed identities.

Rotation & audits

Automate key/secret rotation and review access paths regularly to prevent privilege creep.



2 — The Network Must Not Be Flat

Segmentation is containment. Use VPCs/subnets, micro-segmentation, internal firewalls, and strict east-west controls so a breach doesn't become an enterprise incident.

Segmentation

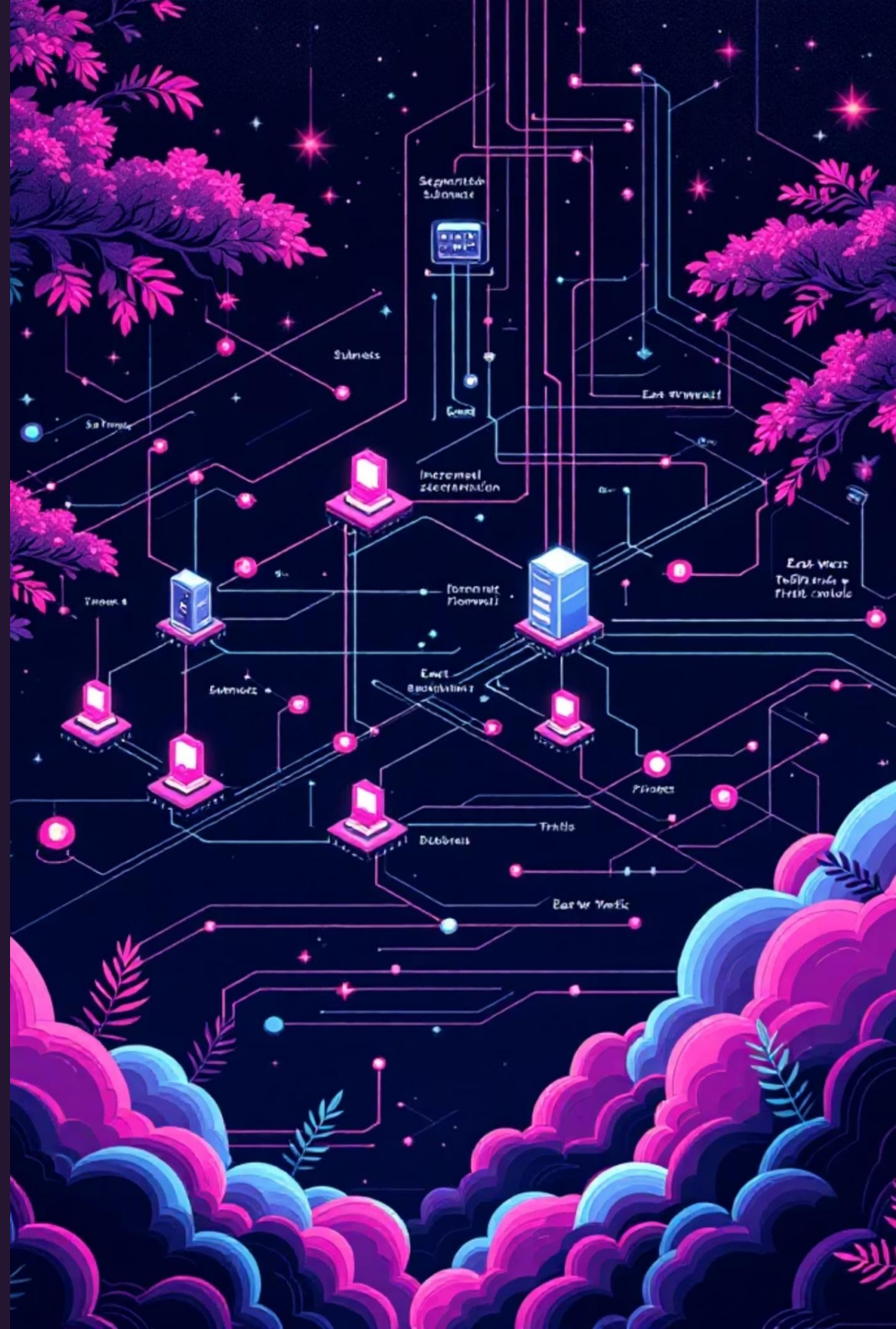
Separate trust zones by function and sensitivity.

Micro-segmentation

Restrict service-to-service paths to least-privilege flows.

Internal firewalls

Enforce policy at network and host layers.



•In Transit



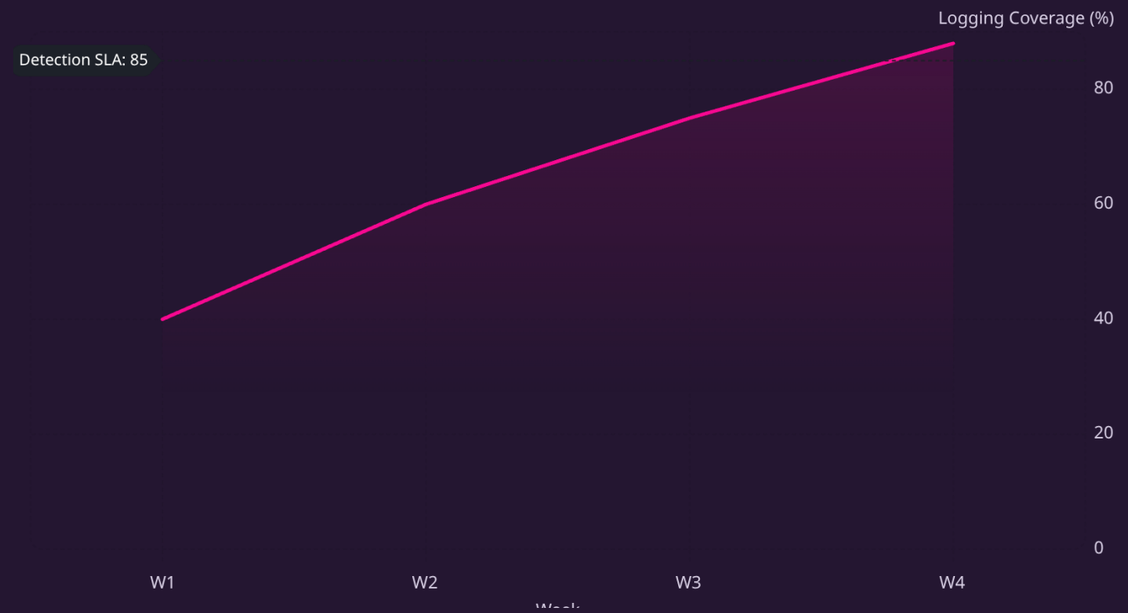
3 – Secrets Must Live Outside Code

Never hardcode credentials, API keys, or connection strings. Prevent leaks by design.

Integrate secret injection at runtime and scan source control for accidental exposures.

- Data Encryption

- At Rest
- In Transit
- In Code



4 — Logging from Day Zero

Logging isn't retrospective—it's the engine for visibility, detection, and response.

- Centralized logs + immutable retention
- Audit trails tied to identity
- Baseline behavior & anomaly detection
- Alerting pipelines with clear SLAs

Aim to reach detection coverage goals early; visibility reduces mean time to detect and contain.



5 – Assume Breach: Design for Reduced Impact

Detect

Continuous monitoring and alerting to surface anomalies fast.

Isolate

Automatically segment and quarantine affected components to limit movement.

Recover

Immutable backups, tested runbooks, and service failover for rapid restoration.

Learn

Post-incident analysis to harden architecture and update threat models.

Ask continually: What can an attacker reach? How quickly can we detect, isolate, and recover? Design to minimize blast radius — not just to prevent.

6 – Zero Trust Architecture

Never Trust, Always Verify

Every access request must be authenticated and authorized, regardless of network location. No implicit trust — not even inside the corporate perimeter.

Identity is the New Perimeter

Enforce MFA, Conditional Access, and SSO for all users. Use managed identities for workloads. The firewall no longer defines trust — identity does.

Continuous Validation & JIT Access

Use Just-In-Time (JIT) elevation via PIM for privileged roles. Continuously re-evaluate trust signals — device health, location, behavior — not just at login.



7 — Threat Modeling: Know Your Attack Surface

Draw the Attack Surface First

Before writing a line of code, diagram all entry points, trust boundaries, data flows, and actors. What can an attacker reach from outside? From inside?

Apply STRIDE Categories

For each component, ask: Spoofing, Tampering, Repudiation, Information Disclosure, Denial of Service, Elevation of Privilege. Document findings as architectural constraints.



8 — DevSecOps: Shift Security Left

Security Gates in CI/CD Pipeline

Embed SAST (static analysis), DAST (dynamic testing), and SCA (dependency scanning) as automated gates. A failed security check blocks the build — not just a warning.

Infrastructure as Code Security

Scan Terraform, Bicep, and ARM templates for misconfigurations before deployment. Tools like Checkov and tfsec catch open storage accounts, public IPs, and missing encryption at design time.



9 – Data Classification & Protection by Design

Classify Before You Build

Label every data type at design time: Public, Internal, Confidential, or Restricted. Classification drives storage choice, access control, encryption level, and retention policy.

PII, PHI & Regulatory Boundaries

Design flows that respect GDPR, HIPAA, and local data sovereignty laws. Architect data residency from day one — retrofitting regional boundaries is expensive and error-prone.

DLP & Key Hierarchy Design

Design DLP policies at the architecture layer — not as a post-deployment filter. Use envelope encryption with a key hierarchy: tenant key wraps data keys. Consider HSMs for high-assurance data.



Important Note

Security Vs Cost

Security Vs Solution Speed





Thank you!

Emad Adel

Multi-Cloud Solutions Architect
Microsoft MVP / MCT